



Carnegie Mellon University
Master of
Software Engineering

Security – basic tactics

LG Architecture Training Program

Paulo Merson

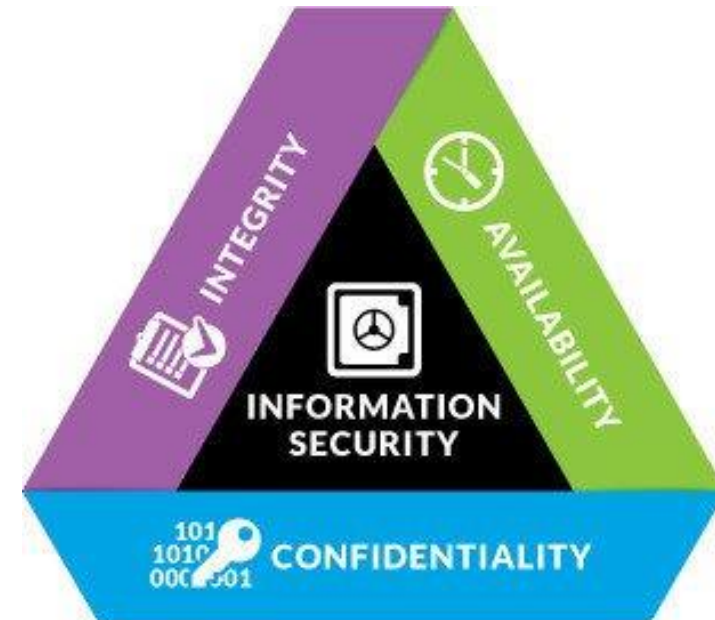
Agenda



➔ Security tactics
Security in the SDLC

Security

- Information security has traditionally 3 aspects:
 - **Confidentiality**: protect data or services from unauthorized access
 - **Integrity**: avoid that data is tampered with (altered without permission)
 - **Availability**: ensure that data and services are functioning for legitimate use



Security tactics

- Verify message integrity
- Limit exposure
- Encrypt data
- IP restriction
- Validate input
- Audit
- Authenticate actors
- Authorize actors

Typical tradeoffs:
- performance
- usability



Verify message integrity

- Helps to detect attacks
- Use checksum or hash to validate data integrity (data was not tampered with or corrupted)
- An algorithm (e.g., SHA-256, Argon2) generates a small data block (hash value or digest) using the message as input
- The message receiver
 - receives the message and the digest
 - computes the digest again and compares it with the one it received

Limit exposure

- Passive defense that helps **resist attacks**
- It consists of decreasing the “attack surface”
 - Reduce visibility of resources in software interfaces
 - Reduce the number of ports, interfaces, and operations available



Encrypt data

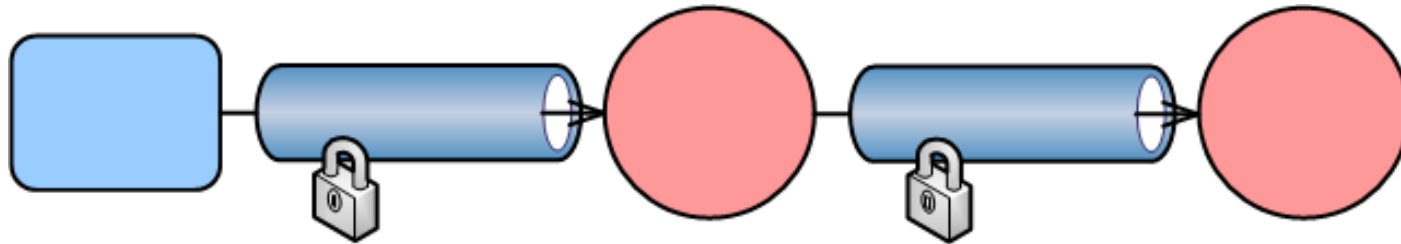
- Helps to **resist attacks**
- Cryptography can be
 - **Symmetric**: same key to encrypt and decrypt
 - **Asymmetric**: public key to encrypt and private key to decrypt
- Encryption can protect data **in transit** and data **at rest**
- For data in transit, encryption can protect
 - the communication channel (e.g., TLS), and/or
 - parts of the message

*PKI can also be used
for digital signature*

TLS to protect data in transit

HTTPS is
HTTP over TLS

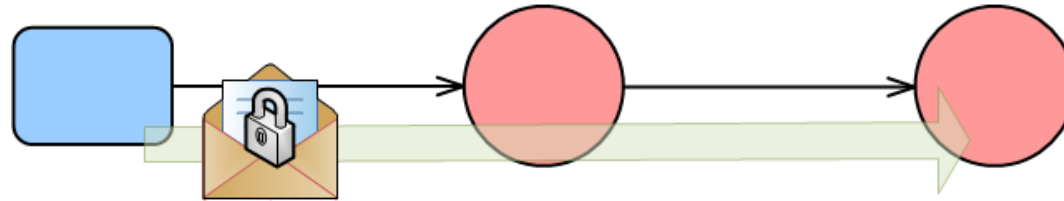
- Transport Layer Security (TLS) is widely used and easy to set up
 - The communication channel is encrypted to prevent traffic sniffing
 - TLS can also verify the identity of the server in a client-server interaction
 - It may also be used to verify the identity of the client (mutual TLS)
 - TLS also performs an integrity check to prevent tampering of messages
- TLS protects messages *point-to-point*, but they are not protected when going through an intermediary



Make sure you are
using TLS
version 1.2 or 1.3

Message-layer security

- With message-layer security we encrypt and sign all or just parts of *the message*
 - The message remains encrypted during transport and processing by intermediaries (**end to end**)



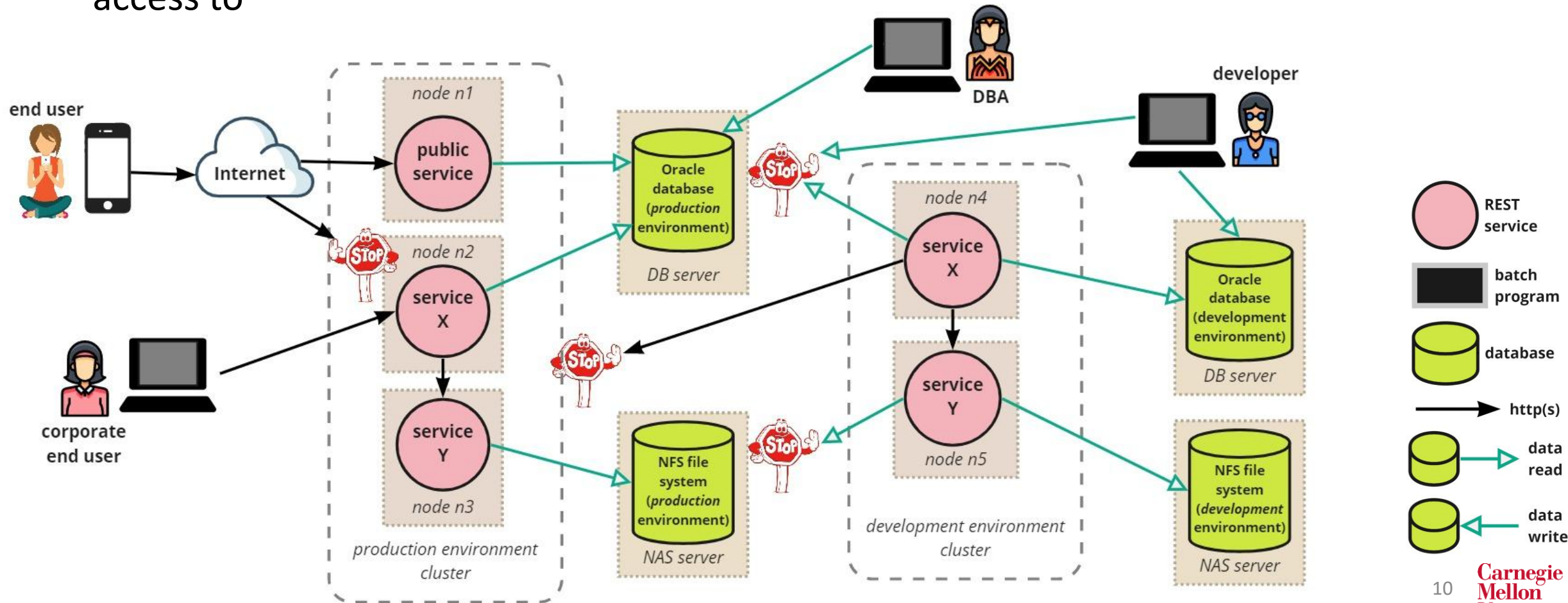
- Sensitive data can be encrypted using, for example,
 - Traditional RSA (asymmetric cryptography)
 - AES (symmetric cryptography)
 - The JOSE standard that includes mechanisms for signing (JWS) and encrypting (JWE) messages

Message-layer security is often used in conjunction with https

IP restriction

IP restriction is
a form of "Limit
Access" tactic

- Ensures services and devices only access other services and devices they need access to



Allowlisting vs denylisting

- IP restriction is aka IP allowlisting
- Allowlisting used to be called whitelisting; denylisting used to be called blacklisting
- They're basic approaches to access control
 - Allowlisting: if not on the list, access is denied
 - Denylisting: if on the list, access is denied

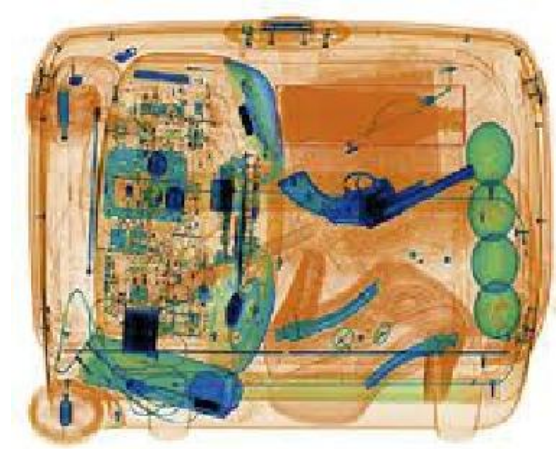
Which one is more secure, allowlisting or denylisting?

Yes, allowlisting is more secure.



Which one is easier to configure and maintain?

Yes, denylisting is easier to manage



Validate input

- Can help to **resist** attacks
- Types of attacks that are prevented with input validation:
 - **Injection** of code that runs on the server side (includes SQL injection, OS command, LDAP)
 - **Cross-site scripting** (XSS), which is injection of script code in a web page
- Input validation should be done on the server side (attackers can alter web frontend code)
- See [this OWASP page](#) for a comprehensive discussion of how to implement this tactic

Audit



- Helps to **recover** from attacks
- After an attack **log records** provide an audit trail of the attacker actions
 - These log records can help us to create better defenses in the future

For that to be effective the system shall log all relevant user/system actions

- Logging may also be useful to detect attacks
 - Intrusion detection systems use access patterns and metrics to detect potential attacks
 - Application-level logging (e.g., unsuccessful login attempts, input validation errors) is also useful in detection
 - Logging tools can generate alerts on specific content in log records



Questions?

Paulo Merson
pmerson@cmu.edu